

PENETRATION TESTING REPORT

MEDIROZA GENERAL HOSPITAL — BLACK-BOX WEB APPLICATION PENTEST

W4-MEDIROZA | CYBERSECURITY | NETWORKWALKS

Pentester Name (Cybersecurity Professional)	Khadija
Program/Batch	B083-Networkwalks
Date	3 October 2026
Modules completed	W4-M1 (Initial Access) W4-M2 (Data Extraction / Password Cracking) W4-M3 (Critical Data Exposure) W4-M4 (Pentest Report)
Client/Target	Mediroza General Hospital — https://medirozahospital.com (written permission already secured by Networkwalks)
Permission secured from client?	Yes
Phases covered	Phase 1: Initial Access Phase 2: Data Extraction (Password Cracking) Phase 3: Critical Data Exposure Phase 4: Reporting

1. Liability Disclaimer

I have performed these activities only against the Mediroza General Hospital training target, for which written permission was already secured by Networkwalks as confirmed in the project brief. All these materials are for education and research purpose only. Do not use anything from here to break the law. The instructor, the authors and Networkwalks are not responsible for what you do with this knowledge. Every action you take is your own responsibility. Misuse can lead to criminal charges, heavy fines, loss of your job and a permanent record. In most countries unauthorised access is a crime even when nothing is damaged.

2. Introduction

This report covers the Week 4 black-box penetration test of Mediroza General Hospital's patient-facing website, medirozahospital.com. It is the Week 4 part of my ongoing internship program at Networkwalks.

The engagement was split into three technical milestones: gaining initial access to confidential patient lab reports (M1), recovering the password protection on those reports (M2), and identifying a further, more critical exposure on the server (M3). This document (M4) presents the full findings.

All commands were run in Kali Linux. Every step below includes the exact command used, the result I observed, a screenshot as evidence (see Section 8), and a short note on why the finding matters from an attacker's point of view.

3. Tools Used

The table below lists each tool used in this report and its purpose.

Tool	Purpose
Kali Linux (VMware VM)	Platform for reconnaissance, exploitation and password cracking
whois, nslookup, dig	Domain registration and DNS reconnaissance
Browser + DevTools (Network tab)	Manual reconnaissance, inspecting client-server traffic
robots.txt / sitemap.xml review	Discovering non-indexed but publicly reachable paths
gobuster	Directory and content discovery against discovered paths
Manual SQL injection testing	Authentication bypass testing on login forms

Tool	Purpose
pdf2john	Extracting crackable hashes from password-protected PDF files
Hashcat 7.1.2 (mode 10500)	Recovering passwords on PDF 1.4 (RC4 128-bit) encrypted files
qpdf	Removing password protection once passwords were recovered
exiftool	Extracting metadata from recovered PDF files

4. Activities Performed

4.1 Milestone 1 — Initial Access

I began reconnaissance against medirozahospital.com using WHOIS, DNS lookups and a review of robots.txt. The robots.txt file explicitly disallowed three paths, each of which I then checked manually:

```
User-agent: *
Disallow: /patient/
Disallow: /staff/
Disallow: /old/
```

Visiting /staff/ returned a server directory listing (LiteSpeed, directory indexing enabled) revealing a login.php file, confirming a staff authentication portal. I tested the staff login form for SQL injection using several payloads (' OR '1'='1' -- and variants); all attempts failed, indicating this form uses parameterised queries or equivalent protection.

The homepage navigation bar also linked directly to the Patient Portal (/patient/login.php), using Username and Password fields. I submitted the following SQL injection payload in the Username field, with the password left blank:

```
Username: admin' --
Password: (blank)
```

This bypassed authentication entirely, without knowledge of any valid patient credentials. The resulting session displayed a "My lab reports" page listing three password-protected pathology reports belonging to three different patients (S. Dlamini, P. Reddy, E. Thompson) — none of whom matched the injected username, confirming the login check itself had been bypassed rather than a legitimate account accessed.

Result: unauthenticated access achieved; 3 confidential patient lab report PDFs retrieved (patient_report_1.pdf, patient_report_2.pdf, patient_report_3.pdf).

4.2 Milestone 2 — Data Extraction (Password Cracking)

Each retrieved PDF was password-protected. pdftinfo confirmed encryption on all three ("Incorrect password" with no password supplied). I extracted a hash from each file for offline cracking:

```
pdf2john patient_report_1.pdf > hash_report1.txt
pdf2john patient_report_2.pdf > hash_report2.txt
pdf2john patient_report_3.pdf > hash_report3.txt
```

John the Ripper failed to load the extracted hashes on this VM ("No password hashes loaded"), despite the PDF format being listed as supported — a local tooling issue rather than a problem with the hashes themselves. I used Hashcat instead (mode 10500, PDF 1.4–1.6 / Acrobat 5-8, RC4 128-bit), against the rockyou.txt dictionary:

```
hashcat -m 10500 -a 0 hash1_clean.txt /usr/share/wordlists/rockyou.txt
```

All three passwords were recovered successfully:

File	Patient	Password recovered	Cracking effort
patient_report_1.pdf	S. Dlamini	123456	Immediate (< 2,000 attempts)
patient_report_2.pdf	P. Reddy	password	Immediate (< 2,000 attempts)

File	Patient	Password recovered	Cracking effort
patient_report_3.pdf	E. Thompson	!@#\$\$%^&	~1 second (73,081 attempts)

I then decrypted the files for review:

```
qpdf --password=123456 --decrypt patient_report_1.pdf patient_report_1_decrypted.pdf
qpdf --password=password --decrypt patient_report_2.pdf patient_report_2_decrypted.pdf
qpdf --password='!@#$$%^&' --decrypt patient_report_3.pdf patient_report_3_decrypted.pdf
```

Result: all 3 files decrypted; confidential pathology content (Full Blood Count, Lipid Profile results) fully readable.

4.3 Milestone 3 — Critical Data Exposure

Following the hint to examine file properties closely, I ran exiftool against the three decrypted PDFs. The first two returned only generic metadata (author "Mediroza Diagnostics Lab", creator "Mediroza CMS 1.4.2"). The third contained an internal comment left by hospital IT staff:

```
Author:      j.malik
Comments:    DB backup moved to /old before site migration, do not delete
```

This matched a path already flagged by robots.txt. Visiting <https://medirozahospital.com/old/> returned a directory listing (directory indexing enabled, no index file present) exposing a single file:

```
Index of /old/
mediroza_db_backup_2019.sql      7k      2026-09-04
```

I downloaded the file without authentication and found it contained two full database tables from the hospital's HR system (database: mediroza_hr):

- staff — 30 records: full name, job title, department, email, phone, national ID number, and monthly salary (ZAR) for every employee.
- shareholders — 10 records: shareholder name, shareholding percentage, shares held, and share class.

The Author field of patient_report_3.pdf ("j.malik") matches staff record #9 in the leaked table — Jameel Malik, IT Systems Administrator — directly corroborating that the exposure was a known, internally documented decision rather than an isolated accident.

Result: full staff salary data and shareholder ownership data retrieved, confirmed by two independent sources (robots.txt + PDF metadata).

5. Risk Analysis / Impact

Based on the information collected during the three milestones, I identified the following risks. Unlike Week 2's reconnaissance-only exercise, these findings were confirmed through direct exploitation, not just observation.

#	Risk / Finding	Evidence / Observation	Potential Impact	Risk Level
1	Sensitive paths disclosed via robots.txt	robots.txt content listing /patient/, /staff/, /old/	Reveals targets for further testing	● Low
2	Directory listing enabled (/old/)	Index of /old/ screenshot	Direct exposure of a sensitive backup file	● High
3	Exposed DB backup: salaries, national IDs, shareholder data	mediroza_db_backup_2019.sql downloaded	Full compromise of staff PII and corporate financial data	● Critical
4	Directory listing enabled (/staff/)	Index of /staff/ screenshot	Reveals internal structure / login endpoint	● Medium
5	SQL injection authentication bypass (patient portal)	admin' -- login bypass	Unauthenticated access to confidential medical records	● Critical

#	Risk / Finding	Evidence / Observation	Potential Impact	Risk Level
6	Weak passwords on encrypted patient PDFs	Hashcat results, 3/3 files cracked	Encryption rendered ineffective; patient data fully exposed	● Critical
7	Internal comment embedded in patient-facing PDF	exiftool metadata on report 3	Confirms known risk acceptance; leaks internal notes to patients	● Critical

Risk level key: ● Critical ● High ● Medium ● Low

Unlike the Week 2 reconnaissance exercise, every finding above was reached through confirmed exploitation (authentication bypass, password recovery, and direct unauthenticated file download) rather than inference from exposed information alone.

6. Recommendations

Based on the findings from this engagement, I recommend the following security improvements:

- Fix the authentication query on the patient portal**
Rewrite the patient portal's login logic to use parameterised queries / prepared statements, matching the protection already present on the staff login.
- Disable directory listing**
Turn off directory indexing (e.g. "Options -Indexes" on LiteSpeed/Apache) across all web-accessible directories, including /old/ and /staff/.
- Remove legacy backup files from the web root**
Delete or relocate old database backups outside any publicly accessible directory, and encrypt backups at rest.
- Enforce strong passwords on protected documents**
Require strong, randomly generated passwords for any password-protected patient documents, or replace password-protected PDFs with an authenticated download system.
- Strip metadata from distributed documents**
Remove author fields and internal comments from all documents before they are generated or sent to patients; review the document generation template in Mediroza CMS.
- Do not rely on robots.txt for access control**
Enforce access restrictions server-side rather than relying on robots.txt, which is publicly readable and provides no real protection.
- Review exposed paths and legacy infrastructure regularly**
Conduct periodic reviews of publicly accessible directories and decommission legacy infrastructure (such as /old/) as a standard step of any site migration.
- Perform security testing with authorization**
Continue penetration testing and reconnaissance only against systems and networks where appropriate authorization has been provided.

7. Conclusion

During Week 4 of my Cybersecurity & Ethical Hacking internship, I completed all four milestones of the Mediroza General Hospital black-box penetration test.

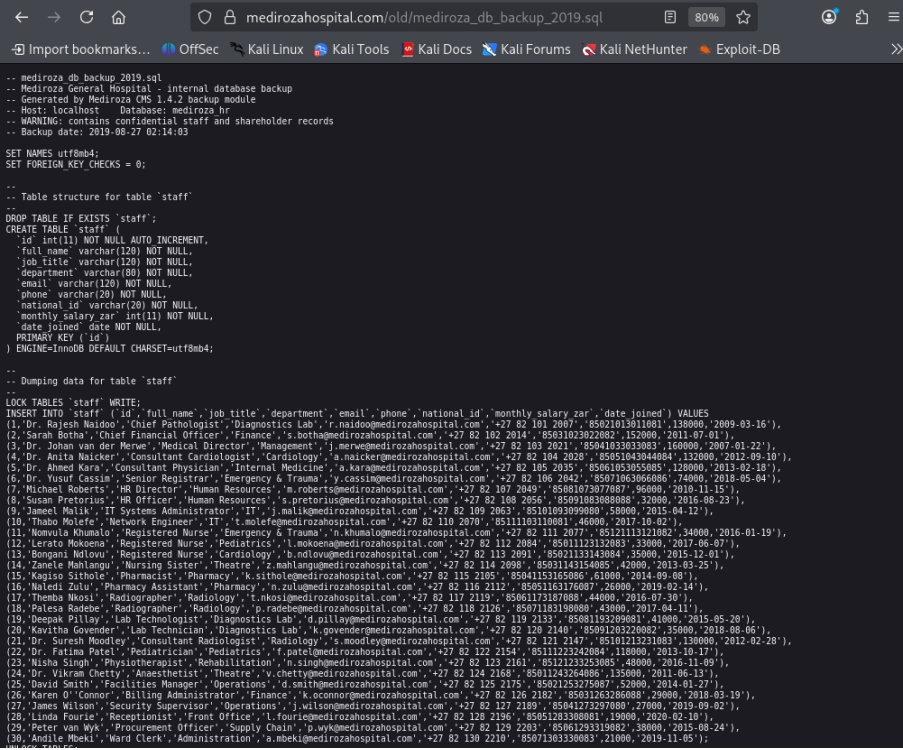
In the initial access phase, a SQL injection flaw in the patient portal login allowed me to bypass authentication entirely and retrieve three confidential patient lab reports. In the data extraction phase, I recovered the passwords protecting all three PDF files using Hashcat against a public wordlist — two of them instantly, as they used the extremely weak passwords "123456" and "password". In the critical data exposure phase, metadata left inside one of the patient PDFs pointed me to

an exposed legacy directory containing a full internal database backup with staff salaries, national ID numbers, and shareholder ownership details.

I learned that no single flaw in this engagement was advanced on its own — SQL injection, server misconfiguration, weak passwords and poor data hygiene combined to create a critical overall exposure. I also learned that metadata left in distributed documents can leak internal operational information independently of the document's intended content, and that robots.txt should never be relied upon as an access control mechanism.

Finally, as with Week 2, I learned that reconnaissance, exploitation and reporting must always be performed within an authorized scope. These activities were completed as part of the assigned educational cybersecurity lab.

8. Evidences Collected



The screenshot shows a web browser window with the address bar displaying 'medirozahospital.com/old/mediroza_db_backup_2019.sql'. The browser's developer tools or a text editor view shows the content of the SQL backup file. The file is a MySQL database backup for 'Mediroza General Hospital - Internal database backup', generated by 'Mediroza CMS 1.4.2 backup module'. It contains a table named 'staff' with columns: 'id', 'full_name', 'job_title', 'department', 'email', 'phone', 'national_id', 'monthly_salary_zar', and 'date_joined'. The backup includes a 'DROP TABLE IF EXISTS' statement, a 'CREATE TABLE' statement, and an 'INSERT INTO' statement with 30 rows of staff data. The data includes names, titles, departments, emails, phone numbers, national IDs, monthly salaries, and date joined for various hospital staff members.

```
-- mediroza db backup 2019.sql
-- Mediroza General Hospital - Internal database backup
-- Generated by Mediroza CMS 1.4.2 backup module
-- Host: localhost Database: mediroza_hr
-- WARNING: contains confidential staff and shareholder records
-- Backup date: 2019-08-27 02:14:03

SET NAMES utf8mb4;
SET FOREIGN_KEY_CHECKS = 0;

--
-- Table structure for table 'staff'
--
DROP TABLE IF EXISTS `staff`;
CREATE TABLE `staff` (
  `id` int(11) NOT NULL AUTO INCREMENT,
  `full_name` varchar(120) NOT NULL,
  `job_title` varchar(120) NOT NULL,
  `department` varchar(80) NOT NULL,
  `email` varchar(120) NOT NULL,
  `phone` varchar(20) NOT NULL,
  `national_id` varchar(20) NOT NULL,
  `monthly_salary_zar` int(11) NOT NULL,
  `date_joined` date NOT NULL,
  PRIMARY KEY (`id`),
  ENGINE=InnoDB DEFAULT CHARSET=utf8mb4;
--
-- Dumping data for table 'staff'
--
LOCK TABLES `staff` WRITE;
INSERT INTO `staff` (`id`,`full_name`,`job_title`,`department`,`email`,`phone`,`national_id`,`monthly_salary_zar`,`date_joined`) VALUES
(1,'Dr. Rajesh Naidoo','Chief Pathologist','Diagnostics Lab','r.naidoo@medirozahospital.com','+27 82 101 2007','85021013011801',130000,'2009-03-16'),
(2,'Sarah Botha','Chief Financial Officer','Finance','s.botha@medirozahospital.com','+27 82 102 2014','85031022022002',152000,'2011-07-01'),
(3,'Dr. Johan van der Merwe','Medical Director','Management','j.merwe@medirozahospital.com','+27 82 103 2021','85041033033003',160000,'2007-01-22'),
(4,'Dr. Anita Naicker','Consultant Cardiologist','Cardiology','a.naicker@medirozahospital.com','+27 82 104 2028','85051043044004',132000,'2012-09-10'),
(5,'Dr. Ahmed Kara','Consultant Physician','Internal Medicine','a.kara@medirozahospital.com','+27 82 105 2035','85061053055005',120000,'2013-02-18'),
(6,'Dr. Yusuf Cassim','Senior Registrar','Emergency & Trauma','y.cassim@medirozahospital.com','+27 82 106 2042','85071063066006',74000,'2018-05-04'),
(7,'Michael Roberts','HR Director','Human Resources','m.roberts@medirozahospital.com','+27 82 107 2049','85081073077007',96000,'2018-11-15'),
(8,'Susan Pretorius','HR Officer','Human Resources','s.pretorius@medirozahospital.com','+27 82 108 2055','85091083088008',32000,'2016-06-23'),
(9,'Jameel Malik','IT Systems Administrator','IT','j.malik@medirozahospital.com','+27 82 109 2063','85101093099009',58000,'2015-04-12'),
(10,'Thabo Molefe','Network Engineer','IT','t.molefe@medirozahospital.com','+27 82 110 2070','85111103110001',46000,'2017-10-02'),
(11,'Nomvula Khumalo','Registered Nurse','Emergency & Trauma','n.khumalo@medirozahospital.com','+27 82 111 2077','85121113121002',34000,'2016-01-19'),
(12,'Lerato Mokoena','Registered Nurse','Pediatrics','l.mokoena@medirozahospital.com','+27 82 112 2084','85011123120003',35000,'2017-06-07'),
(13,'Bongani Ndlovu','Registered Nurse','Cardiology','b.ndlovu@medirozahospital.com','+27 82 113 2091','85021133143004',35000,'2015-12-01'),
(14,'Zanele Mahlangu','Nursing Sister','Theatre','z.mahlangu@medirozahospital.com','+27 82 114 2098','85031143154005',40000,'2013-03-25'),
(15,'Kwesi Sithole','Pharmacist','Pharmacy','k.sithole@medirozahospital.com','+27 82 115 2105','85041153165006',61000,'2014-09-08'),
(16,'Naledi Zulu','Pharmacy Assistant','Pharmacy','n.zulu@medirozahospital.com','+27 82 116 2112','85051163176007',26000,'2019-02-14'),
(17,'Thembu Mxosi','Radiographer','Radiology','t.mxosi@medirozahospital.com','+27 82 117 2119','85061173187008',44000,'2016-07-30'),
(18,'Palesa Radebe','Radiographer','Radiology','p.radebe@medirozahospital.com','+27 82 118 2126','85071183198009',43000,'2017-04-11'),
(19,'Deepak Pillay','Lab Technologist','Diagnostics Lab','d.pillay@medirozahospital.com','+27 82 119 2133','85081193199001',41000,'2015-05-20'),
(20,'Kavitha Govender','Lab Technician','Diagnostics Lab','k.govender@medirozahospital.com','+27 82 120 2140','85091203220002',35000,'2018-08-06'),
(21,'Dr. Suresh Moodley','Consultant Radiologist','Radiology','s.moodley@medirozahospital.com','+27 82 121 2147','85101213231003',130000,'2012-02-28'),
(22,'Dr. Fatima Patel','Pediatrician','Pediatrics','f.patel@medirozahospital.com','+27 82 122 2154','85111223242004',118000,'2013-10-17'),
(23,'Nisha Singh','Physiotherapist','Rehabilitation','n.singh@medirozahospital.com','+27 82 123 2161','85121233253005',48000,'2016-11-09'),
(24,'Dr. Vikram Chetty','Anesthetist','Theatre','v.chetty@medirozahospital.com','+27 82 124 2168','85011243264006',135000,'2011-06-13'),
(25,'David Smith','Facilities Manager','Operations','d.smith@medirozahospital.com','+27 82 125 2175','85021253275007',52000,'2014-01-27'),
(26,'Karen O'Connor','Billing Administrator','Finance','k.oconnor@medirozahospital.com','+27 82 126 2182','85031263286008',29000,'2018-03-19'),
(27,'James Wilson','Security Supervisor','Operations','j.wilson@medirozahospital.com','+27 82 127 2189','85041273297009',27000,'2019-09-02'),
(28,'Linda Fourie','Receptionist','Front Office','l.fourie@medirozahospital.com','+27 82 128 2196','85051283308001',19000,'2020-02-10'),
(29,'Peter van Wyk','Procurement Officer','Supply Chain','p.wyk@medirozahospital.com','+27 82 129 2203','85061293319002',38000,'2015-08-24'),
(30,'Andile Meki','Ward Clerk','Administration','a.meki@medirozahospital.com','+27 82 130 2210','85071303330003',21000,'2017-11-05');
```

← → ↻ 🏠

🔒 📄 medirozahospital.com/staff/ 80% ☆

🔗 Import bookmarks... 🛡️ OffSec 🐧 Kali Linux 🧰 Kali Tools 📄 Kali Docs 🗨️ Kali Forums 🏹 Kali NetHunter 🔥 Exploit-DB >>

Index of /staff/

Name ↕	Last Modified ↕	Size ↕
📁 Parent Directory		
📄 login.php	2026-09-04 02:05	3k

Proudly Served by LiteSpeed Web Server at medirozahospital.com Port 443

Emergency: +27 11 555 0100 | Open 24/7

+

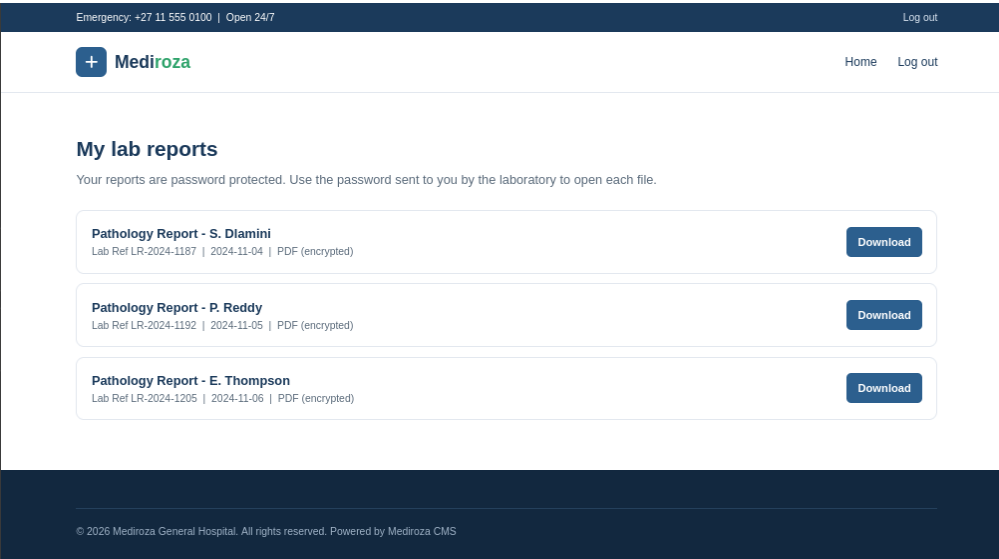
Mediroza

My lab reports

Your reports are password protected. Use the password sent to you by the laboratory to open each file.

Pathology Report - S. Dlamini

Lab Ref LR-2024-1187 | 2024-11-04 | PDF (encrypted)



File / Item	Description
Screenshot — /old/ directory listing	Shows mediroza_db_backup_2019.sql exposed, unauthenticated
Screenshot — /staff/ directory listing	Shows login.php exposed via directory indexing
Screenshot — Patient Portal "My lab reports"	Proof of authentication bypass and access to patient reports
patient_report_1/2/3.pdf (+ _decrypted copies)	Original encrypted and password-recovered patient reports

-End-

Author

Khadija
Cybersecurity & Ethical Hacking Intern, Batch B083

Project Information

Program Name: Cybersecurity program at Networkwalks | **Week:** 04 | **Repository:** NetworkWalks-Cybersecurity-EthicalHacking-Batch83